



AWS 멀티 어카운트 기술 지원 접근 전략 및 침해사고 대응 고도화(with Kiro)

메가존클라우드(MEGAZONECLOUD)
허준, June Her
2026.05.28

Contents

1. 발표자 약력 소개
2. Tech Support Service 소개
3. Multi-Account 기술 지원 접근 전략 for Kiro
4. Kiro(Q developer) 및 AWS Login 연동 방안
5. 주요 고객 사례 및 Kiro(Q developer) 를 통한 문제 해결
6. Abuse 대응용 특화 Context를 가진 Kiro Cli-Agents
7. Lessons Learned





소속 메가존클라우드

유닛 Commercial Managed
Tech Support Service
Tech Support 1 Unit

직책 Unit Leader

경력

메가존클라우드 2022 ~ 현재

AWS 통합빌링 고객(KR, JP, US, VN, HK 등) 대상 기술 지원

: 서포트 포탈을 통한 SR(Service Request) 기반 Technical (Solution/Problem/Incident) Support 대응 업무 수행

2025 ~ 2026 Cloud Support Engineer, Unit Leader

2023 ~ 2025 Cloud Support Engineer, Leader

2022 ~ 2023 Cloud Support Engineer, Manager

원스(WINS) 2017 ~ 2022

보안 솔루션 엔지니어(선임) : Anti-DDoS System, IPS(Intrusion Protecting System)

: 현대해상, 대신증권, 현대자동차, JB우리캐피탈 등 정보보안 시스템 구축/유지보수 지원

금융권 대상 DDoS 모의훈련, 서버해킹 훈련 지원 경력 다수(20회 이상)

: 금융보안원, 해양수산부 주관 등

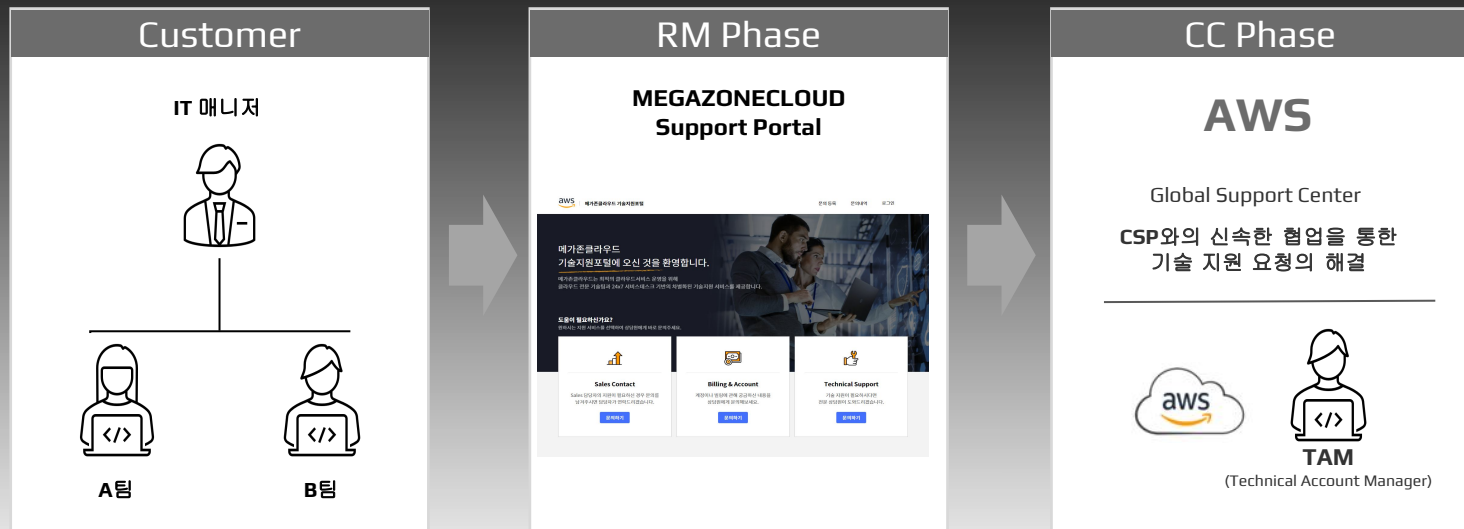
메가존클라우드 Tech Support Service 소개

메가존클라우드 'Tech Support Service'는 고객이 클라우드를 사용하면서 겪을 수 있는 기술적 어려움을 해결하기 위해 최적화된 기술적 경험제공을 목표로 합니다.
(Support Service **기능의 전문화**, 글로벌 서포트를 위한 **표준화된 서비스 역량 강화**, 서비스 확장을 위한 **안정적 지원**을 지향합니다.)

- 1) Fundamental of all services, professional service area in itself
- 2) Standardization of the service system of Global Support
- 3) Support for stable sales structure and service extension

메가존클라우드 Tech Support Service 소개

고객과 메가존클라우드 기술지원조직의 **일원화된 소통채널로 Support Portal을 운영합니다.**
이를 통해 업무처리(기술지원, 장애처리 및 일반문의)와 커뮤니케이션 이력관리를 제공합니다.
(한국, 일본, 미국, 베트남, 홍콩 등 글로벌 고객의 Service Request 대응)



※ RM: Resolution within MSP(MZC) · CC: Collaboration with CSP(AWS)

AWS 서포트 플랜

AWS 클라우드를 운영

Unified Operation

AWS 카운트다운 (기본/프리미엄)
AWS 관리형 서비스
AWS Incident Detection and Response

AWS 기반 엔터프라이즈급 핵심 시스템
전체 운영
Ex) 대규모 엔터프라이즈 환경 전체 운영
단계

- 선제적 모장애 감지 및 해결 지원 5분(인시던트 관리 엔지니어가 지원)
- 모니터링, 문제 해결 및 개선
- 지정된 도메인 전문가와의 지속적인 아키텍처 검토

Enterprise Support

AWS상의 비즈니스 핵심 및 미션
크리티컬 워크로드 운영
Ex) 기업 핵심 시스템 운영 단계

- 선제적 지원 서비스 제공
- 전담 TAM 서비스 제공
- 15분 이내 초기 응답
- 5분 이내 응답 및 신속한 복구 시간 (IDR 이용 시)

Business Support+

AWS상의 실 서비스 운영 단계

- Support Engineers 를 통한
제약없는 케이스 및 기술지원

Basic Support

개발 및 테스트 환경

AWS 서포트 플랜

AWS 클라우드 도입 과정

AWS 카운트다운 (기본/프리미엄)
AWS 관리형 서비스

단계

* 선제적 모니터링, 문제 해결 및 개선

Enterprise Support

w/ Incident Detection and Response

AWS상의 비즈니스 핵심 및
미션 크리티컬 워크로드 운영
Ex) 기업 핵심 시스템 운영 단계

- 선제적 지원 서비스 제공
- 담당 TAM 서비스 제공
- 15분 이내 초기 응답
- 5분 이내 응답 및 신속한 복구 시간 (IDR 이용 시)

Enterprise Support

AWS상의 중간 규모의 미션 크리티컬

선제적 지원 서비스 일부 제공

- TAM 서비스 제공

Partner-led Support

AWS 파트너 주도 지원(PLS)은
AWS 지원의 경험을 바탕으로
구축된 전문 도구와 지식을
활용하여 고품질의 지원을
제공할 수 있도록 지원

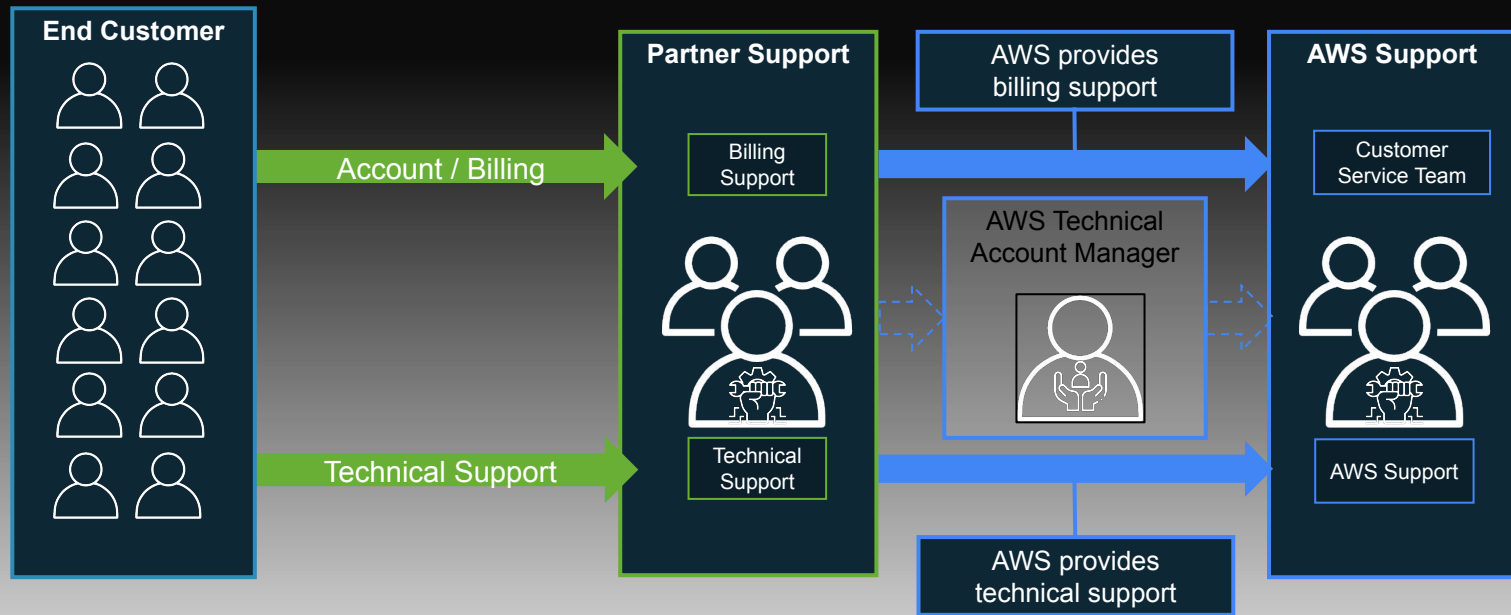
- 선제적 지원 서비스 제공
- 담당 TAM 서비스 제공
- 15분 이내 초기 응답
- 진단 Tool 제공
- Backed by AWS Support

Business

Developer Support

개발 및 테스트 환경

Partner-Led Support Flow



Billing 및 Technical Support에 대해 **Partner**가 우선적으로 지원을 하며, 필요시 AWS에 Escalation을 통해 지원을 제공

AWS Summit Seoul 2026 Tech Support Booth



MegazoneCloud 부스 방문
200명 고객 대상 데모 시연 / 상담



AI-driven Report
(Security•FinOps)



Brochure

PARTNER-LED SUPPORT

MEGAZONECLOUD TECH SUPPORT

Contact Us mzc_tss@megazone.com | MegazoneCloud Tech Support Service Unit

메가존클라우드 Tech Support 및 파트너 주도 기술지원 (Partner-led Support)
문의사항이 있으시면 편하게 연락 부탁드립니다.

Report Download

우측 QR을 통해 PLS 고객에게 제공되는 PLS-SR(Security Review) 및
PLS-Finops 리포트를 다운로드 후 참고하세요.



Multi-Organizations 기술지원 접근 전략

메가존클라우드 고객과 통합빌링된 수천개의 고객 계정에대한 기술지원은?



Multi-Organizations 기술지원 접근 전략



MANAGED SERVICE

(리소스 변경 권한 보유)
고객사 환경에 프로비저닝과
핸즈온이 가능한 형태

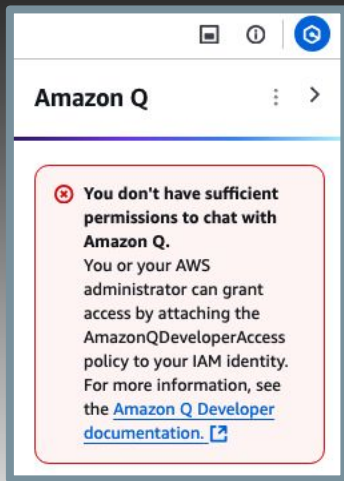


SUPPORT SERVICE

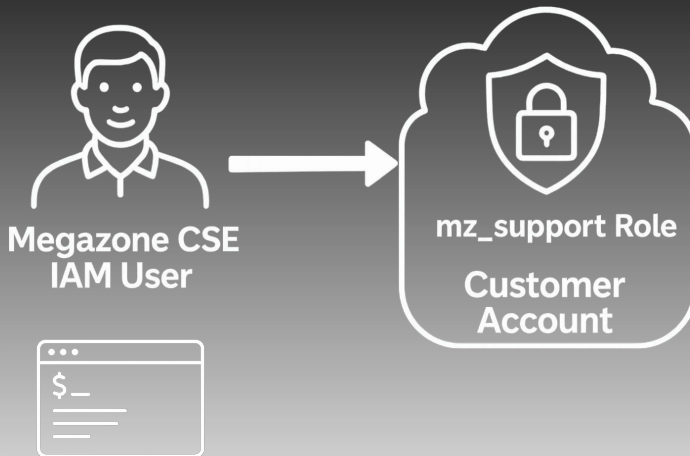
Read-Only 권한으로
트러블 슈팅 및 기술 지원

Multi-Organizations 기술지원 접근 전략 for Kiro

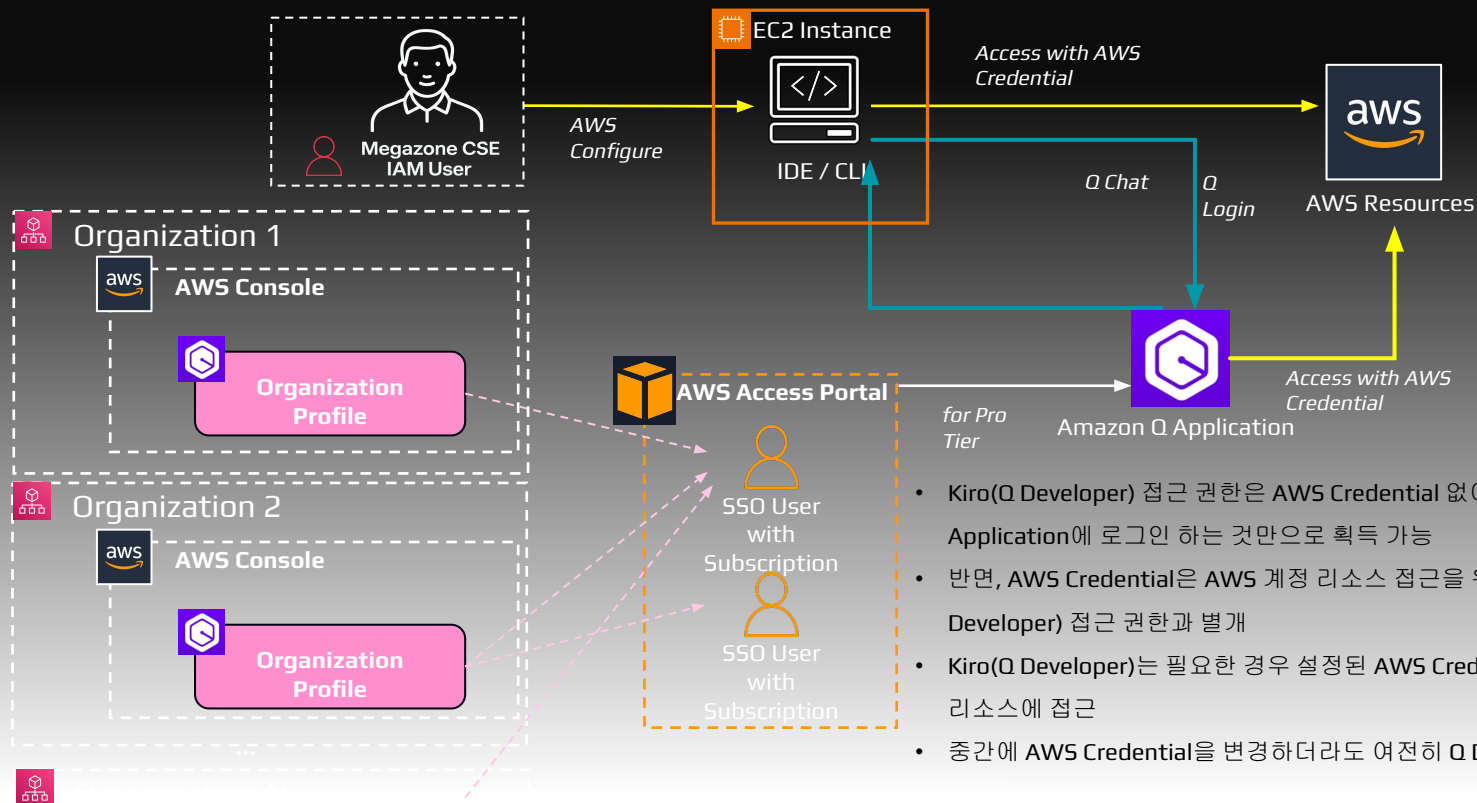
기존에는 콘솔에서 Switch Role을 통한 기술 지원 수행
KIRO 를 통한 분석을 위해 CLI 환경 사용 필요성 대두



Q콘솔접근제한



Multi-Organizations 기술지원 접근 전략 for Kiro



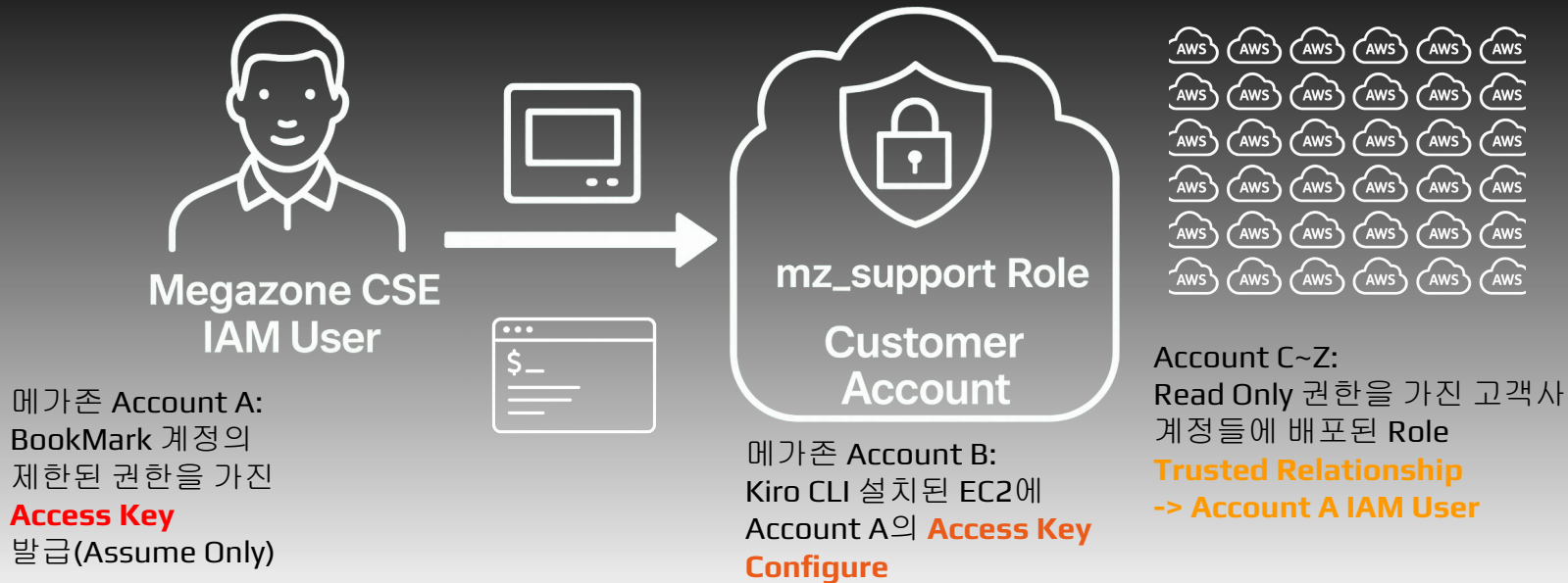
- Kiro(Q Developer) 접근 권한은 AWS Credential 없이도 Amazon Q Application에 로그인 하는 것만으로 획득 가능
- 반면, AWS Credential은 AWS 계정 리소스 접근을 위한 것으로 Kiro(Q Developer) 접근 권한과 별개
- Kiro(Q Developer)는 필요한 경우 설정된 AWS Credential을 통해 AWS 계정 리소스에 접근
- 중간에 AWS Credential을 변경하더라도 여전히 Q Developer 세션 유지됨

Multi-Organizations 기술지원 접근 전략 for Kiro

IAM User 계정 A → Kiro CLI가 설치된 계정 B → 고객사 계정 C~Z에 접근

A, B 메가존 소유

C~Z 고객사 소유



Multi-Organizations 기술지원 접근 전략 for Kiro

CLI STS를 통하여 고객 환경 Assume에 성공한 모습 (AISA~)

```
> aws sts assume-role --role-arn "arn:aws:iam::619[redacted]:role/mz_[redacted]" --role-session-name [redacted]_MZC 를 수행 해 줘

Using tool: use_aws (trusted)
...
● Running aws cli command:

Service name: sts
Operation name: assume-role
Parameters:
- role-session-name: "[redacted]_MZC"
- role-arn: "arn:aws:iam::619[redacted]:role/mz_s[redacted]"
Region: us-east-1
Label: 역할 전환
...
● Completed in 1.509s

> 역할 전환이 성공했습니다.

새로운 임시 자격증명:
● **Access Key ID**: ASIA[redacted]
● **Assumed Role ARN**: arn:aws:sts::619[redacted]:assumed-role/mz_s[redacted]_MZC
● **만료 시간**: 2025-09-09T06:34:59+00:00 (약 1시간 후)

이제 계정 61[redacted]의 mz_[redacted] 역할로 AWS 작업을 수행할 수 있습니다.
```

TIP

```
aws sts assume-role
--role-arn
arn:aws:iam:accountic
role/mz_xxxxx
```

ASIA VS AKIA

클라우드 임시 자격증명 :

****Access Key ID**:** ASIA2

****Assumed Role ARN**:** arn:aws:sts::619

Multi-Organizations 기술지원 접근 전략 for Kiro

TIP IAM 고유 접두사에 대한 이해

접두사	리소스 유형	접두사	리소스 유형
AKIA☆☆☆	엑세스키	ANPA	관리형 정책
ANVA	관리형 정책 내 버전	APKA	퍼블릭 키
AROA ☆	역할(Role)	ASCA	인증서
ASIA☆☆	임시(STS) 액세스 키	AIDA☆☆	IAM 사용자
ABIA	AWS STS 서비스 보유자 토큰	ACCA	컨텍스트별 자격 증명
AGPA	사용자 그룹	AIPA	EC2 인스턴스 프로파일

ABSK는? 무엇일까요

Multi-Organizations 기술지원 접근 전략 for Kiro

Kiro CLI(EC2)에 저장된 자격증명과 고객 환경의 임시 자격증명을 혼동하는 증상 발생

> 기본 프로필로 EC2 인스턴스 목록을 조회하겠습니다 :

Using tool: use_aws (trusted)

:

● Running aws cli command:

Service name: ec2

Operation name: describe-instances

Parameters:

Profile name: default

Region: us-east-1

Label: List EC2 instances

:

● Execution failed after 1.688s:

An error occurred (UnauthorizedOperation) when calling the DescribeInstances operation: You are not authorized to perform this operation. User: arn:aws:iam::012345678901:user/mz_suy is not authorized to perform: ec2:DescribeInstances because no identity-based policy allows the ec2:DescribeInstances action

Multi-Organizations 기술지원 접근 전략 for Kiro

> aws sts assume-role --role-arn "arn:aws:iam::{accountid}:role/mz_xxxxxxx" 로 어셈하고, **mz-support** 프로파일에 자격증명을 저장해줘.

mz-support 프로파일로 {accountid} 계정에서 서울리전의 EC2 리스트를 조회해 줘.

```
> aws sts assume-role --role-arn "arn:aws:iam::70[redacted]:role/mz_ε[redacted]" 로 어셈해하고, mz-support 프로파일에 자격증명을 저장해줘.
mz-support 프로파일로 706505390350 계정에서 서울리전의 EC2 리스트를 조회해 줘.
```

```
✂ Using tool: use_aws (trusted)
```

```
⋮
```

```
● Running aws cli command:
```

```
Service name: sts
```

```
Operation name: assume-role
```

```
Parameters:
```

```
- role-session-name: "mz-support-session"
```

```
- role-arn: "arn:aws:iam::7[redacted]:role/mz_ε[redacted]"
```

```
Profile name: default
```

```
Region: us-east-1
```

```
Label: Assume IAM role mz_[redacted]
```

```
⋮
```

```
● Completed in 1.528s
```

```
> 이제 mz-support 프로파일에 자격증명을 저장하겠습니다 :
```

Multi-Organizations 기술지원 접근 전략 for Kiro

Assume Role의 임시 크레덴셜을 특정 프로파일을 지정하고, 명시적 언급하여 성공

> 이제 mz-support 프로파일로 서울 리전의 EC2 인스턴스를 조회하겠습니다 :

```
Using tool: use_aws (trusted)
:
● Running aws cli command:

Service name: ec2
Operation name: describe-instances
Parameters:
Profile name: mz-support
Region: ap-northeast-2
Label: List EC2 instances in Seoul region
:
● Completed in 1.55s
```

> 성공적으로 서울 리전의 EC2 인스턴스를 조회했습니다 !

```
EC2 인스턴스 정보 :
● **인스턴스 ID** : i-
● **이름** : r-
● **상태** : running (실행 중)
● **인스턴스 타입** : t3.medium
● **가용 영역** : ap-northeast-2a
● **프라이빗 IP** : 
● **키 페어** : mcad
● **시작 시간** : 
● **환경** : Elastic Beanstalk 환경 (mozo-backend)
```

Multi-Organizations 기술지원 접근 전략 for Kiro

TIP 지속적으로 오류가 발생하는 경우 ~/.aws/config, ~/.aws/credentials, ~/.bashrc 내 자격증명 초기화

```
[ec2-user@ip-172-31-36-84 .aws]$ cat ~/.aws/config
[default]
region = ap-northeast-2
output = json
[profile mz-support]
region = ap-northeast-2
[ec2-user@ip-172-31-36-84 .aws]$ cat ~/.aws/credentials
[default]
aws_access_key_id = AKIA
aws_secret_access_key =
[mz-support]
aws_access_key_id = ASI
aws_secret_access_key =
aws_session_token =
[ec2-user@ip-172-31-36-84 .aws]$
[ec2-user@ip-172-31-36-84 .aws]$
[ec2-user@ip-172-31-36-84 .aws]$
[ec2-user@ip-172-31-36-84 .aws]$
[ec2-user@ip-172-31-36-84 .aws]$ cat ~/.bashrc
```

증가하는 클라우드 보안 사고들

AWS S3 버킷 등의 AWS 리소스 접근 시 액세스 키를 사용하는 것은 매우 흔하며, 보안 사고의 주요 원인 중 하나입니다.

GitHub에 노출된 AWS 키로 인한 개인정보 유출, SSRF(Server-Side Request Forgery)를 통한 AWS 키 탈취, 운영자의 관리 소홀로 인한 액세스 키 유출 등 다양한 보안 사고 사례가 보고되고 있습니다.

최신뉴스

랜섬웨어·해킹 급증...침해사고 신고 1천건 돌파

개인정보위, 개인정보 유출된 16개 사업자 과징금 등 제재
안전조치 소홀에 따른 해킹, 업무상 실수 등으로 개인정보 유출

보안사고 예시

- 고객이 AWS EC2에서 랜섬웨어를 발견했다고 보고
- 고객이 과금 요금의 급격한 증가를 발견
- 공격자가 고객 시스템의 자격 증명을 추출하려 함
- AWS가 고객 계정에서 SES 스팸을 전송했다고 알림
- AWS가 고객 계정에서 의심스러운 계정 활동이 감지되었을 알림
- 고객의 AWS API 키가 GitHub에 공개됨
- 고객의 S3 데이터와 버킷이 삭제됨
- 고객의 루트 AWS 계정에 접근할 수 없음

장기 자격증명 (액세스 키) 사용의 위험성

일반적으로 애플리케이션에
하드코딩 되어 사용됨

텍스트는 손쉽게
복사-붙여넣기 가능

설정이 애플리케이션 코드에
내장되어 있을 수 있음



설정 파일에 평문으로 작성
될 수 있음

파일과 코드, 텍스트는 **팀 간에**
걸쳐 공유됨

코드가 **Public 저장소**에
업로드 될 수 있음

장기 자격증명 (액세스 키) 사용의 위험성

클라우드 보안사고 피해 현황
퍼블릭 클라우드 침해 1건당 일평균 7천만원, 매
년 10% 이상 증가하는 위협

AccessKey 유출 — 왜 가장 위험한가
탈취 후 1~5분 내 자동 악용, 클라우드 침해의 1순
위 공격 벡터

임시 자격증명 제공을 위한 AWS Login 사용

AWS 블로그

집

블로그 ▾

에디션 ▾

AWS 보안 블로그

'aws login' 명령어를 통해 개발자가 AWS에 간편하게 접속할 수 있습니다.

작성자: Shreya Jain 및 Sowjanya Rajavaram 2025년 11월 19일 | [AWS CLI](#), [AWS Identity and Access Management \(IAM\)](#), [AWS Security Token Service](#), [개발자 도구](#), [기초 \(100\)](#), [보안](#), [ID 및 규정 준수](#) | [Permalink](#) | [댓글](#) | [공유하다](#)

이제 AWS에서 로컬 개발을 위한 자격 증명을 더욱 간편하고 안전하게 얻을 수 있습니다. 새로운 AWS 명령줄 인터페이스([AWS CLI](#)) 명령어를 사용하면 장기 액세스 키를 생성하고 관리할 필요 없이 AWS에 가입한 직후 바로 개발을 시작할 수 있습니다. [AWS 관리 콘솔](#)

`aws login` 에 로그인할 때 사용하는 것과 동일한 방식으로 로그인하면 됩니다.

이 블로그에서는 새로운 명령어를 사용하여 AWS CLI, AWS 소프트웨어 개발 키트(AWS SDK) 및 이를 기반으로 구축된 도구 또는 애플리케이션에서 사용할 임시 자격 증명을 워크스테이션에 얻는 방법을 보여드리겠습니다. `aws login`.

AWS에 대한 프로그래밍 방식 액세스 시작하기

`aws login` 다음 섹션에 설명된 대로 AWS Management Console 로그인 방법을 사용하여 해당 명령을 실행할 수 있습니다.

시나리오 1: IAM 자격 증명 사용(루트 또는 IAM 사용자)

루트 또는 IAM 사용자 이름 및 암호를 사용하여 프로그램 방식으로 자격 증명을 얻으려면 다음 단계를 따르세요.

- 최신 [AWS CLI](#) (버전 2.32.0 이상)를 설치하십시오.
- 명령어를 실행하세요. `aws login`.
- 기본 리전을 설정하지 않은 경우 CLI는 사용자가 원하는 [AWS 리전을 지정하도록 요청합니다](#)(예: `us-east-2`, `eu-central-1`). CLI는 사용자가 이 프롬프트에 입력한 리전을 기억합니다.

```
Last login: Mon Nov 17 11:18:23 on tty9000
$ aws login
No AWS region has been configured. The AWS region is the geographic location of your AWS resources.
If you have used AWS before and already have resources in your account, specify which region they were created in. If you have not
created resources in your account before, you can pick the region closest to you: https://docs.aws.amazon.com/global-infrastructure/
re/latest/regions/aws-regions.html.
You are able to change the region in the CLI at any time with the command "aws configure set region NEW_REGION".
AWS Region [us-east-1]:
```

그림 1: CLI 지역 프롬프트

<https://aws.amazon.com/ko/blogs/security/simplified-developer-access-to-aws-with-aws-login/>

임시 자격증명 제공을 위한 AWS Login 사용

작년 말 새로 출시된 **[AWS login]** 기능을 통한 **Assume Role** 진행이 가능합니다!

해당 기능을 통해, 이제 AWS에서 로컬 개발을 위한 자격 증명을 더욱 간편하고 안전하게 얻을 수 있습니다.

새로운 AWS 명령줄 인터페이스(AWS CLI) 명령어를 사용하면 장기 액세스 키를 생성하고 관리할 필요 없이 AWS에 가입한 직후 바로 개발을 시작할 수 있습니다. AWS 관리 콘솔 `aws login` 에 로그인할 때 사용하는 것과 동일한 방식으로 로그인하면 됩니다 .

1. 최신 AWS CLI (버전 **2.32.0 이상**)를 설치하십시오.
2. 인스턴스를 새로운 연결을 하나 만들어주세요(KIRO 창 아님!)

아래 명령어 를 실행하세요

```
aws login --remote
```

임시 자격증명 제공을 위한 AWS Login 사용

기존 사용하던 IAM User 계정 정보 사용 가능

3. URL 을 복사해서 새로운 창에서 열기(세션이 겹치지 않게 타 세션창 혹은 브라우저 사용 권고!!)

```
Browser will not be automatically opened.  
Please visit the following URL:  
  
https://ap-northeast-2.signin.aws.  
4159-aldB-678239afdiscode_challe  
tioncode_challenge=le8V5FfeY-Cmv-  
fcross-devicestate=5f1799a7-4dda  
on.com%2Fv1%2Fsessions%2Fconfirma  
Enter the authorization code displayed on your device.
```

Sign in to AWS

Continue with an active session



By continuing, you allow AWS CLI, SDKs, and local developer tools to use your credentials until your session expires.

megazone [REDACTED]
m [REDACTED]

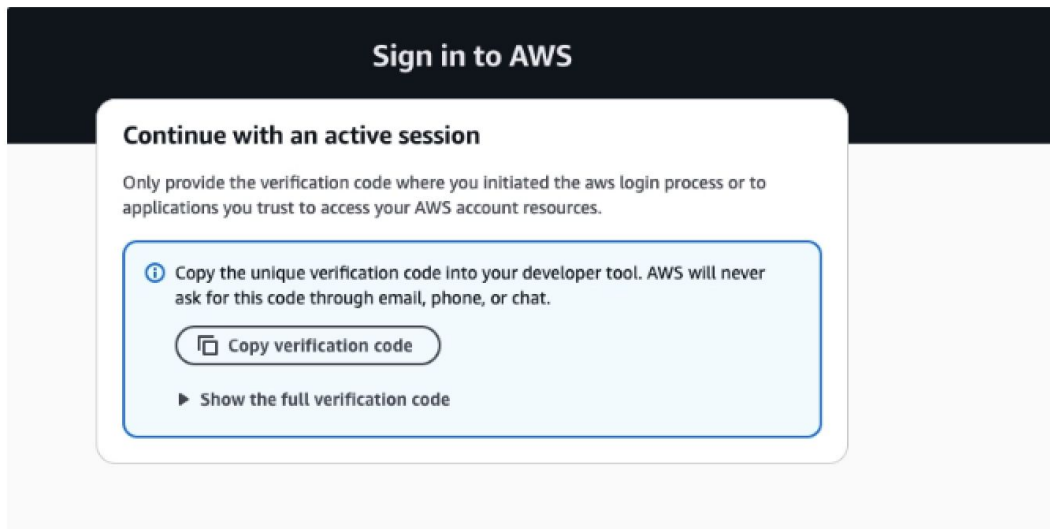
OR

 Sign into new session

임시 자격증명 제공을 위한 AWS Login 사용

4. [redacted] 계정 [redacted] IAM User로 로그인

5. 코드 복사



6. 원래 창으로 돌아와 복사한 코드 붙여넣기

```
Unable to create or refresh login credentials due to insufficient permissions. You may be missing permission for the 'signin:CreateOAuth2Token' action.  
[ec2-user@ip-172-31-11-136 ~]$
```

임시 자격증명 제공을 위한 AWS Login 사용

```
Updated profile default to use arn:aws:iam::08[redacted] credentials.
[ec2-user@ip-172-31-11-138 ~]$ aws sts get-caller-identity
{
  "UserId": "AI[redacted]GJ3ZLRJZ4",
  "Account": "08[redacted]",
  "Arn": "arn:aws:iam::089[redacted]"
}
[ec2-user@ip-172-31-11-138 ~]$
```

```
Unable to create or refresh login credentials due to insufficient permissions. You may be missing permission for the 'signin:CreateOAuth2Token' action.
[ec2-user@ip-172-31-11-138 ~]$
```

오류 발생 시 특정 IAM 유저에 OAuth2Token 권한이
부여되었는지 확인!

임시 자격증명 제공을 위한 AWS Login 사용

7-1) Kiro 창을 잠시 닫아두고 Linux 명령창에서 아래 링크로 이동

```
cd /home/ec2-user/.aws/login/cache
```

7-2) 생성된 json 파일 확인

```
cat c18e0c86de5[REDACTED]ld881895516d7122321bb11af53d06e.json
```

7-3) 해당 내용 복사 후 Kiro로 이동

7-4) 아래 자격증명으로 환경변수에 설정해줄것을 요청

[Kiro] > cd /home/ec2-user/.aws/login/cache에 위치한 json 내 임시 자격증명을 aws configure 환경 변수로 설정해줘

7-5) STS Assume Role 예시

aws sts assume-role --role-arn "arn:aws:iam::accountid:role/" --role-session-name n 명령어로 어썅하고 mz-support으로 프로파일을 지정해줘. 방금 생성한 mz-support 프로파일로 account 계정 도요리전에서 어떠한 인스턴스들을 사용하고 있는지 알려줘

Multi-Organizations 기술지원 접근 전략 for Kiro

Running aws cli command (using tool: aws):

Service name: ec2

Operation name: describe-instances

Parameters:

Profile name: mz-support

Region: ap-northeast-1

Label: 도쿄 리전 EC2 인스턴스 조회 - Completed in 1.955s

계정의 도쿄 리전 (ap-northeast-1)에 총 9개의 EC2 인스턴스가 있습니다.

실행 중 (Running) - 6개 :

1. stg-ec2-batch-01 (i-0c7252)
 - 타입: r6i.large
 - Private IP: 10.2
 - AZ: ap-northeast
2. stg-ec2-bastion-01 (i-01e)
 - 타입: m6i.large (Windows)
 - Private IP: 10.
 - AZ: ap-northeast
3. stg-ec2-wordpress-01 (i-01b3ed)
 - 타입: c6i.large
 - Private IP: 10.2
 - AZ: ap-northeast
4. stg2-ec2-ext-01 (i-0573c9ccc)
 - 타입: m6i.xlarge
 - Private IP: 10.2
 - AZ: ap-northeast

주요 고객 사례-1

Functions (0)

Filter by attributes or search by keyword

Function name

Access denied to :
You don't have permission to perform this action.

UnknownError

번역 ▼

안녕하세요,

귀하의 AWS 계정이 제3자에 의해 부적절하게 액세스되었을 수 있으므로 연락드립니다. 이 알림을 검토하고 즉각적인 조치를 취하여 계정을 보호하고 복구하세요.

귀하의 계정을 보호하기 위해 일부 AWS 서비스를 사용하는 기능을 일시적으로 제한했습니다.

액세스를 복구하려면 (5)일 이내에 AWS에 문의하고 아래 지침을 따라야 합니다. (5)일 이내에 AWS에 문의하지 않으면 귀하의 계정이 정지될 수 있습니다. 귀하의 계정에서 의심스러운 리소스를 종료할 수 있으며, 종료된 일부 리소스는 복구할 수 없습니다.

이 응답이 도움이 되었습니까? 평가하려면 여기를 클릭하세요.

★★★★★

아시아 태평양 (서울) 리소스

Lambda 함수

49

코드 스토리지

3.2GB

(4%/75GB)

Abuse 사례

A사 Abuse 발생으로 인한 서비스 셧다운 대응 사례

Abuse 원인

- Abuse 발생으로 인해, 계정에 신규 자원 생성 Block으로 인한 장애 발생

조치 내역

- AWS Outbound Case 내 Compromise 관련 사항 분석
- 유출 의심되는 IAM User, Access Key Rotation 조치 및 비밀번호 변경
- 비인가 생성 의심 리소스 삭제 및 MFA 미설정된 IAM User 설정
- 이후 Trust & Safety 팀에 리소스 생성 Block 해제 요청

개선 사항

- AWS Health 및 AWS Outbound Case를 모니터링하여 Account Compromise가 발생한 경우 빠르게 인지하도록 상황 전파 체계 개선

주요 고객 사례-2

< 계정 탈취자 (해커)가 고객 담당자인 것처럼 가장하여 AWS Case Reply >

I take this matter seriously and understand the importance of ensuring that recipients only receive emails they have explicitly agreed to. I will thoroughly review my email-sending practices to determine the cause of the complaints. I will start by checking my recipient lists to ensure they consist exclusively of users who opted in to receive communications. If I find any outdated or improperly obtained addresses, I will remove them immediately. Additionally, I will verify that all email content aligns with what recipients expect to receive and that unsubscribe options are clearly visible and functional. I will also examine recent campaigns to ensure that message frequency and branding are consistent. This includes making sure that emails are not sent too frequently, and that the branding aligns with what recipients signed up for. If I discover discrepancies in message type or content, I will address them right away to prevent further complaints. Once these changes are implemented, I will monitor bounce and complaint metrics closely to ensure everything is in order moving forward. I will provide you with a detailed report outlining the root cause of the issue, the specific improvements made, and how these changes will prevent similar issues from occurring in the future

저는 이 문제를 심각하게 받아들이고 있으며, 수신자가 명시적으로 동의한 이메일만 수신하도록 하는 것의 중요성을 잘 알고 있습니다. 불만의 원인을 파악하기 위해 이메일 발송 방식을 철저히 검토할 것입니다. 먼저 수신자 목록을 확인하여 수신 동의를 한 사용자만 포함되도록 할 것입니다. 오래되었거나 부적절하게 획득한 주소를 발견하면 즉시 삭제할 것입니다. 또한, 모든 이메일 내용이 수신자가 기대하는 내용과 일치하는지, 수신 거부 옵션이 명확하게 표시되고 작동하는지 확인할 것입니다. 또한 최근 캠페인을 검토하여 메시지 빈도와 브랜딩의 일관성을 유지할 것입니다. 여기에는 이메일이 너무 자주 발송되지 않도록 하고, 수신자가 동의한 내용과 브랜딩이 일치하는지 확인하는 것이 포함됩니다. 메시지 유형이나 내용에 불일치가 발견되면 추가 불만이 발생하지 않도록 즉시 해결하겠습니다. 이러한 변경 사항이 구현되면 반송 및 불만 지표를 면밀히 모니터링하여 향후 모든 것이 원활하게 진행되도록 할 것입니다. 문제의 근본 원인, 구체적으로 개선된 사항, 이러한 변경 사항을 통해 향후 유사한 문제가 발생하지 않도록 방지할 수 있는 방법을 설명하는 자세한 보고서를 제공해 드리겠습니다.

Abuse 사례

B사 Abuse(계정 Compromise) 및 계정 탈취자의 Case 답변을 통한 추가 대응 사례

Abuse 원인

- 고객사 MFA 비활성화 등 계정 취약점 발생 SES 서비스 통해 스팸메일 대량 발송

조치 내역

- AWS Outbound Case 내 Compromise 관련 사항 분석
- AWS TAM - MZC Tech Support 공조하여 고객 담당자 컨택 후 계정 탈취자 활동내역 확인
- 고객사에서 사용하지 않는 SES 서비스 사용중지
- MFA 설정을 하지 않은 사용자 삭제 (이슈 발생한 사용자)

개선 사항

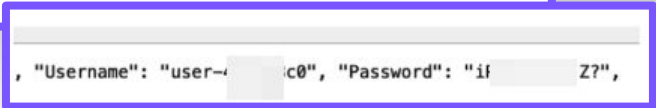
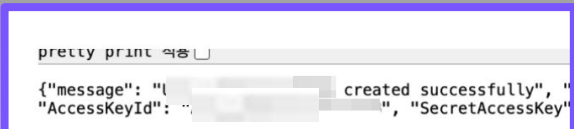
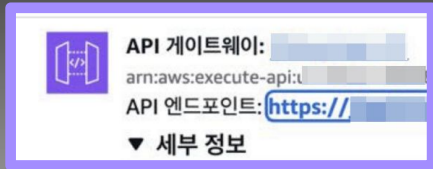
- Root 계정 및 모든 IAM 계정 MFA 적용

주요 고객 사례-3

- Abuse 조치를 완료하였으나, 고객 및 메가존클라우드에서 생성하지 않은 신규 사용자가 계속 생성되는 증상 확인

- API-GW 기반의 신규 백도어를 발견함

Event name	Event time	User name	Event source
CreateUser			iam.amazonaws.com
CreateUser			iam.amazonaws.com



Abuse 사례

C사 API-Gateway 기반 IAM User 및 Access Key 생성 백도어 대응 사례

Abuse 원인

- 백도어를 통한 인가되지 않은 IAM User 지속생성 및 추가자원 생성시도

조치 내역

- 기존 사례처럼 IAM User 비밀번호 변경 및 Access Key Rotation으로 해결 및 CloudTrail 분석을 통한 비인가 리소스 삭제 이후 Outbound Case에 조치사항을 업데이트 하는 것으로 종결되는 듯하였으나, 지속 생성되는 불특정 IAM User(user-abcxxxxx)로 인하여 백도어 의심
- API Endpoint에 접근시 신규 유저(엑세스키, 로그인 정보)등을 반환하는 람다, API Gateway가 발견되어 삭제 처리 진행

개선 사항

- Account Compromise 관련 침해사고 발생 시 Api-Gateway 및 람다 연동한 리소스가 있는지 확인 및 CreateUser로 인한 백도어 유무 확인 프로세스 개선
- IAM 개수 및 Credential 수를 정기적으로 체크 하는 모니터링 메트릭 추가

주요 고객 사례-4

다만, 고객님의 환경을 추가로 확인한 결과 03/02 기준으로 일부 리전에서 여전히 비용이 발생하고 있는 것으로 확인됩니다.

이에 따라, 해당 리전들에 생성된 자원을 다시 한 번 확인해 주시고, 의도치 않게 생성된 자원일 경우에는 추가 비용 방지를 위해 삭제(또는 Terminate) 처리해 주실 것을 권장드립니다.

확인 후 조치 내역을 공유해 주시면 추가로 점검하여 안내드리겠습니다.
감사합니다.

03/02 비용이 발생한 리전 :

1. Africa (Cape Town)
2. Asia Pacific (Hyderabad)
3. Asia Pacific (Jakarta)
4. Asia Pacific (Malaysia)
5. Asia Pacific (Melbourne)
6. Asia Pacific (Mumbai)
7. Asia Pacific (New Zealand)
8. Asia Pacific (Seoul)
9. Asia Pacific (Singapore)
10. Asia Pacific (Sydney)
11. Asia Pacific (Taipei)
12. Asia Pacific (Thailand)
13. Asia Pacific (Tokyo)
14. Canada (Central)
15. Europe (Ireland)
16. Europe (London)
17. Europe (Milan)
18. Europe (Spain)
19. Europe (Zurich)
20. Israel (Tel Aviv)
21. Mexico (Central)
22. Middle East (Bahrain)
23. South America (São Paulo)
24. US East (N. Virginia)
25. US East (Ohio)
26. US West (N. California)

Abuse 사례

Access Key 탈취 이후 D사 EC2, ECS, SageMaker 등 고비용 리소스 생성 후 Region Opt-Out 사례

Abuse 원인

- Access Key 탈취 이후, 비인가 리소스를 모두 삭제한 줄 알았으나 지속됨. 특정 리전이 비활성화 상태에 있었기 때문에 메가존클라우드 기술지원팀에서 해당 리전 내 리소스의 상세한 CloudTrail API 이력 조회가 불가

조치 내역

- 이상 비용이 줄어들지 않는 부분을 파악하여, 리전 활성화 후 비인가 리소스 삭제

개선 사항

- 리전 활성화(Enable) 작업은 계정 보유자(Root 또는 권한이 있는 IAM 사용자)만 수행 가능한 영역으로, 메가존클라우드 기술지원팀에서 고객님의 대신해 리전을 활성화하여 리소스를 조회해드릴 수 없었던 점
- Abuse 발생 시 리전 비활성화 여부를 체크하는 로직 강화

주요 고객 사례-5

⚠️ 긴급: 5월 █일 기준 노출된 Access Key AK: █에서 █건의 Bedrock invocation이 여전히 발생 중. █일이 경과하였으나 공격이 지속되어 비용 피해가 계속 누적되고 있는 상황.

고객 측에 노출 키 삭제, 기존 세션 Revoke, Bedrock 서비스 차단 3단계 완료 확인 및 CloudTrail 상 Bedrock 호출이 0으로 수렴하는지 검증 요청.

Abuse 사례

E사 Bedrock LLM Hijacking 사례

Abuse 원인

- 다량의 IAM User, 액세스키 유출로 인하여 Bedrock LLM Invoke Model을
- 리전별/모델별로 수행하여 천문학적인 금액이 발생함

AWS Marketplace

AWS Marketplace software usage|eu-west-1|Million Input Tokens Global (Claude Opus 4.6 (Amazon Bedrock Edition)) (5) x 2,146.96
AWS Marketplace software usage|eu-west-1|Cache Write Tokens - Standard, Global (Claude Opus 4.7 (Amazon Bedrock Edition)) (6,25) x 1,117.30
AWS Marketplace software usage|eu-west-1|Million Cache Write Input Tokens Global (Claude Opus 4.6 (Amazon Bedrock Edition)) (6,25) x 425.51
AWS Marketplace software usage|eu-west-1|Million Response Tokens Global (Claude Opus 4.6 (Amazon Bedrock Edition)) (25) x 105.48
AWS Marketplace software usage|eu-west-1|Input Tokens - Standard, Global (Claude Opus 4.7 (Amazon Bedrock Edition)) (5) x 495.72

조치 내역

- 유출된 IAM/엑세스 키 삭제 및 Invoken Model 발생 여부 모니터링

개선 사항

가능한 경우 SCP를 통하여 차단,
AI/ML관련 서비스를 사용하지 않는 고객의 경우 아래 내용을 Deny를 기본적으로 적용

```
"bedrock:CreateModelInvocationJob",  
"bedrock:InvokeModelWithResponseStream",  
"bedrock:CreateFoundationModelAgreement",  
"bedrock:PutFoundationModelEntitlement",  
"bedrock:InvokeModel",  
"bedrock:Converse",  
"bedrock:ConverseStream",
```

Quiz-3

2026 단일 Account 하루 최대 피해 금액은?

LLM Hijacking으로 인한 최단 시간 최대 피해

LLMjacking (2024~ 신규 폭증)

피해 단위 : 일당 \$46K ~ \$100K+

탈취 키로 **Bedrock·OpenAI·Anthropic·Gemini**
호출. 프록시 서비스로 재판매 — 토큰 비용이
GPU 채굴보다 자릿수 이상 비쌈.

모델 / 서비스별 일간 피해액

특징

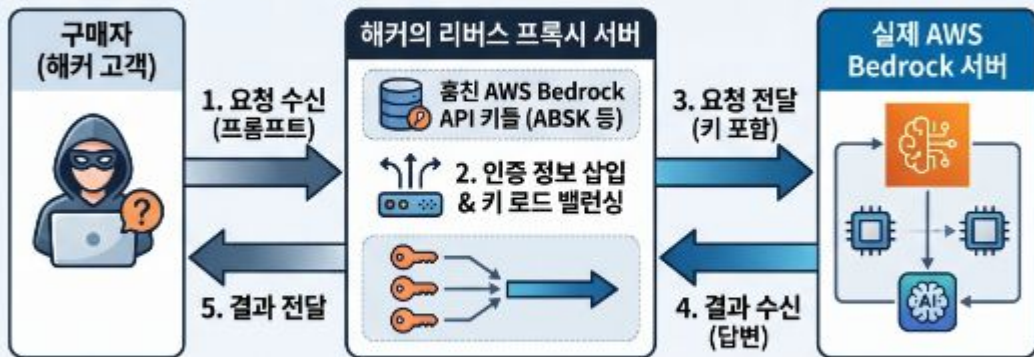
- **InvokeModel API** 조용한 호출 — CloudTrail에 기록되나 탐지
지연
- AI 제재 회피용 우회 사용 사례 (러시아·중국)
- 공격 시간 단위 자체가 **Daily**로 짧아짐

모델 / 서비스	일간 피해액
AWS Bedrock (Claude)	최대 \$46,000/일
AWS Bedrock (Claude 3 Opus)	최대 \$100,000+/일
Google Gemini	\$82,000 / 48h

LLM Hijacking을 하는 이유?

LM 하이재킹: 리버스 프록시 악용 동작 구조도

1. & 2. 리버스 프록시 악용 시나리오



3. 해커가 리버스 프록시를 쓰는 이유



4. 일반 프록시 vs 리버스 프록시 비교

구분	포워드 프록시	리버스 프록시
대리 대상	클라이언트	서버
주요 목적	익명성, 차단 우회	보안, 로드 밸런싱
해킹 활용	IP 숨기기	API 키 재판매

Kiro를 사용한 문제 해결-1(CloudTrail 분석)

> 성공적으로 계정 관련 이벤트를 찾았습니다! CloudTrail 로그에서 다음과 같은 중요한 계정 관련 이벤트들을 확인할 수 있습니다:

■ 계정 [redacted] root 계정 이메일 변경 내역 조회 결과

■ 주요 발견 사항

계정 이메일 변경 관련 이벤트는 직접적으로 발견되지 않았지만, 다음과 같은 계정 관련 활동들이 확인되었습니다:

▶ 최근 계정 관련 활동 (2025년 8월 -9월)

1. 연락처 정보 변경 (PutContactInformation)

- **2025-09-01 19:06:16** : adminprod 사용자가 연락처 정보 업데이트
- **2025-09-01 18:18:21** : adminprod 사용자가 연락처 정보 업데이트
- **2025-08-28 17:21:08** : g[redacted]-eks-dev 사용자가 연락처 정보 업데이트
- **2025-08-28 17:14:13** : g[redacted]-eks-dev 사용자가 연락처 정보 업데이트

2. 대체 연락처 관리 (PutAlternateContact/DeleteAlternateContact)

- **2025-08-28 16:32:47** : OPERATIONS 연락처 설정
- **2025-08-28 16:32:35** : SECURITY 연락처 설정
- **2025-08-28 16:31:04** : BILLING 연락처 설정
- **2025-08-28 16:37:37** : BILLING 연락처 삭제
- **2025-08-28 16:37:35** : OPERATIONS 연락처 삭제
- **2025-08-28 16:37:32** : SECURITY 연락처 삭제

3. Root 계정 활동

- **2025-08-28 17:43:46** : Root 사용자 (el[redacted])가 계정 정보 조회
- **2025-06-30 - 2025-07-01** : Root 사용자의 다양한 계정 정보 조회 활동

▲ 중요 참고 사항

1. Root 계정 이메일 변경 이벤트 미발견: CloudTrail에서 UpdateAccountAttributes 또는 직접적인 root 이메일 변경 이벤트는 발견되지 않았습니다.

2. 가능한 원인:

- 이메일 변경이 조회 기간 (2023-01-01 이후) 이전에 발생
- 해당 이벤트가 CloudTrail에 기록되지 않는 유형일 가능성
- 다른 AWS 서비스나 콘솔을 통한 변경

3. 추가 조사 방법:

- AWS Support를 통한 계정 변경 이력 요청
- AWS Organizations (조직 계정인 경우) 로그 확인
- 더 긴 기간의 CloudTrail 로그 분석

현재 CloudTrail 로그에서는 연락처 정보 변경은 확인되지만, root 계정의 이메일 주소 변경에 대한 직접적인 기록은 찾을 수 없었습니다.

Copyright 2026 © MEGAZONECLOUD CORP. ALL RIGHT RESERVED.

조화한 인터넷주소는 한국인터넷진흥원(KISA)이 아닌 다른 제의 기관에서 관리하고 있습니다.
 이 사례한 내용은 해당 인터넷주소를 관리하는 Whois 조사 서비스를 이용하여 주시기 바랍니다.

(한국인터넷진흥원 Whois 서비스를 검열하여 해외 IP주소를 반복 질의하는 경우 해당
 대량 Whois 인터넷주소관리기구 정책에 의해 차단될 수 있음을 알려드립니다.)

아사아테넷망의 Whois 서비스 : <http://wq.apnic.net/apnic-bin/whois.pl>
 북미지역 인터넷주소관리기구 : <https://www.arin.net>
 유럽지역 Whois 서비스 : <https://aaps.db.ripe.net/db-web-ui/query>
 남미지역 Whois 서비스 : <http://lacnic.net/cgi-bin/lacnic/whois?lg=EN>
 아프리카지역 인터넷주소관리기구 : <http://afrinic.net>

%whois % [whois.apnic.net]
 % Whois data copyright terms http://www.apnic.net/db/dbcopyright.html

% Information related to 180.251.192.0 - 180.251.255.255'

% Abuse contact for '180.251.192.0 - 180.251.255.255' is 'abuse@telkom.co.id'

inetnum: 180.251.192.0 - 180.251.255.255
 netname: TLKM-BB-SERVICE 180.251.255.255
 descr: Menara Multimedia Lt. 7
 descr: Jl. Kebonsirih No.12
 descr: JAKARTA
 country: ID
 admin-c: AR16
 tech-c: HM44
 abuse-c: A1591
 status: ASSIG
 mnt-by: MAIN
 mnt-irt: IRT-ID
 last-modified: 202
 source: APNIC

irt: IRT-IDTE
 address: PT. TI
 address: Indib
 address: Kebon
 address: Jakar
 e-mail: abuse
 abuse-mailbox: ab
 admin-c: RFR2
 tech-c: TP63C
 auth: # Filter
 remarks: abus
 mnt-by: MAIN
 last-modified: 202
 source: APNIC

Kiro를 사용한 문제 해결-1(CloudTrail 분석)

✓ Conversation history has been compacted successfully!

> 이 CloudTrail 로그는 이전 대화 요약에서 언급된 MFA 비활성화 이벤트의 대규모 발생을 명확히 보여줍니다. 주요 분석 결과:

MFA 비활성화 이벤트 분석

시간대별 패턴

- **2025-09-08**: Root 계정 MFA 비활성화 (root(██████████))
- **2025-09-02**: 대규모 MFA 비활성화 작업 (19:06-19:07 UTC)
- **2025-09-01**: Root 계정 MFA 비활성화 (Authapp)
- **2025-08-28**: Root 계정 MFA 비활성화 (root-account-mfa-device)

주요 특징

1. 대량 비활성화 작업 (2025-09-02)

- 동일한 시간대 (19:06-19:07)에 다수 사용자 MFA 비활성화
- Root 계정이 모든 작업 수행 (mfaAuthenticated: false)
- 동일한 IP 주소에서 실행 (156.14██████████6)

2. Root 계정 MFA 변경

- 여러 차례에 걸친 Root 계정 MFA 디바이스 교체
- 각기 다른 MFA 디바이스명 사용

Kiro를 사용한 문제 해결-1(CloudTrail 분석)

2025-08-28 (수요일)

17:38:07 UTC ☒ **EnableMFADevice**

- **사용자** : AWS Root User

- **디바이스** : Authapp

- **수행자** : root (AWS Internal)

- **IP** : AWS Internal

17:35:18 UTC ☐ **DeactivateMFADevice**

- **사용자** : AWS Root User

- **디바이스** : root-account-mfa-device

- **수행자** : root (encored)

- **IP** : 43.██.██.253 🇮🇩 Indonesia, Jagirsidosermo

7:

0: ### 2025-09-01 (일요일)

1: **14:07:41 UTC** ☒ **EnableMFADevice**

2: - **사용자** : AWS Root User

3: - **디바이스** : cloud_realtime_mfa

4: - **수행자** : root (encored)

5: - **IP** : 221.██.██.205 🇰🇷 Seoul, Gangnam-gu

6:

7: **14:05:27 UTC** ☐ **DeactivateMFADevice**

8: - **사용자** : AWS Root User

9: - **디바이스** : Authapp

0: - **수행자** : root (encored)

Kiro를 사용한 문제 해결-2(엑세스 로그 분석)



Kiro를 사용한 문제 해결-2(엑세스 로그 분석)

 해결방안 및 권장사항

AWS Well-Architected 기반

즉시 조치사항 (24시간 내)

1. 504 타임아웃 문제 해결

문제 타겟: 10.175.8.6:80 (86건 여러 발생)

조치방법:

- 해당 타겟 서버의 CPU/메모리 사용률 확인
- 애플리케이션 로그에서 `/MF/000/ap-
helpmessage/get/viewdata API` 처리 시간 확인
- 데이터베이스 쿼리 성능 점검 (특히 `helpmessage` 관련 쿼리)
- 필요시 해당 타겟을 일시적으로 드레인하여 트래픽 분산

```
# 타겟 드레인 명령어
aws elbv2 modify-target-  
es --target-group-arn arn:aws:elasticloadbalancing:ap-northeast-1-  
TG01/0a8dbf6ba61d3d4f --  
=deregistration_delay.timeout_seconds,Value=30
```

2. ALB 타임아웃 설정 조정

현재 설정: 기본 타임아웃 (60초 추정)

권장 조치:

- 타겟 그룹의 헬스체크 타임아웃 확인 및 조정
- ALB의 idle timeout 설정 확인 (기본 60초)
- 백엔드 애플리케이션의 처리 시간에 맞춰 타임아웃 조정

```
# 타겟 그룹 헬스체크 설정 확인
aws elbv2 describe-target-health --target-group-arn arn:aws:elasticloadbalancing:ap-north-1-  
b6f6ba61d3d4f
```

3. 500 여러 백엔드 서버 점검

주요 타겟: 10.175.0.46:80 (25건), 모든 타겟에서 산발적 발생

조치방법:

- 각 백엔드 서버의 애플리케이션 로그 확인
- 데이터베이스 연결 풀 상태 점검
- 메모리 누수 또는 가비지 컬렉션 이슈 확인
- 세션 관리 및 캐시 상태 점검

Abuse 대응용 특화 Context를 가진 Kiro Cli-Agents



Custom Agent

- 특정 워크플로 및 사용 사례에 맞게 구성 가능한 맞춤형 AI 어시스턴트
- JSON 구성 파일을 통해 도구, 권한, 컨텍스트를 사전 정의
-> 불필요한 도구 제한, 도구 동작 세부 파라미터 구성 가능

Agent 생성 명령어 : `/agent create -name [name]`

```
"resources": [  
  "file://AmazonQ.md",  
  "file://AGENTS.md",  
  "file://README.md",  
  "file://.amazonq/rules/**/*.md",  
  "file:///home/ec2-user/agentcontext/SES_Abuse.md",  
  "file:///home/ec2-user/agentcontext/Suspicious Account Activity Detected Abuse.md",  
  "file:///home/ec2-user/agentcontext/Vulnerability.md",  
  "file:///home/ec2-user/agentcontext/Content_Abuse.md",  
  "file:///home/ec2-user/agentcontext/Activity base Abuse.md",  
  "file:///home/ec2-user/agentcontext/supervisor.md"  
],
```

```
"tools": [  
  "fs_read",  
  "execute_bash",  
  "use_aws",  
  "gh_issue",  
  "knowledge",  
  "thinking",  
  "todo_list",  
  "@awslabs.cloudtrail-mcp-server",  
  "@mcp_server_name/mcp_tool_name",  
  "@mcp_server_name_without_tool_specification_to_include_all_tools"  
],
```

Abuse 대응용 특화 Context를 가진 Kiro Cli-Agents

특정 에이전트로 시작하는 명령어 : `$ kiro-cli --agent [name]`

```
For more information, try '--help'.
[ec2-user@ip-172-31-36-84 ~]$ kiro-cli --agent abuse
WARNING: MCP server 'awslabs.cloudtrail-mcp-server' is already configured in agent config. Skipping duplicate from legacy mcp.json.
✓ aws-aco-netfiix loaded in 3.56 s
▲ 1 of 4 mcp servers initialized. Servers still loading:
- awslabs.cloudtrail-mcp-server
- awslabs.aws-diagram-mcp-server
- awslabs.aws-documentation-mcp-server
```

KIRO

Did you know?

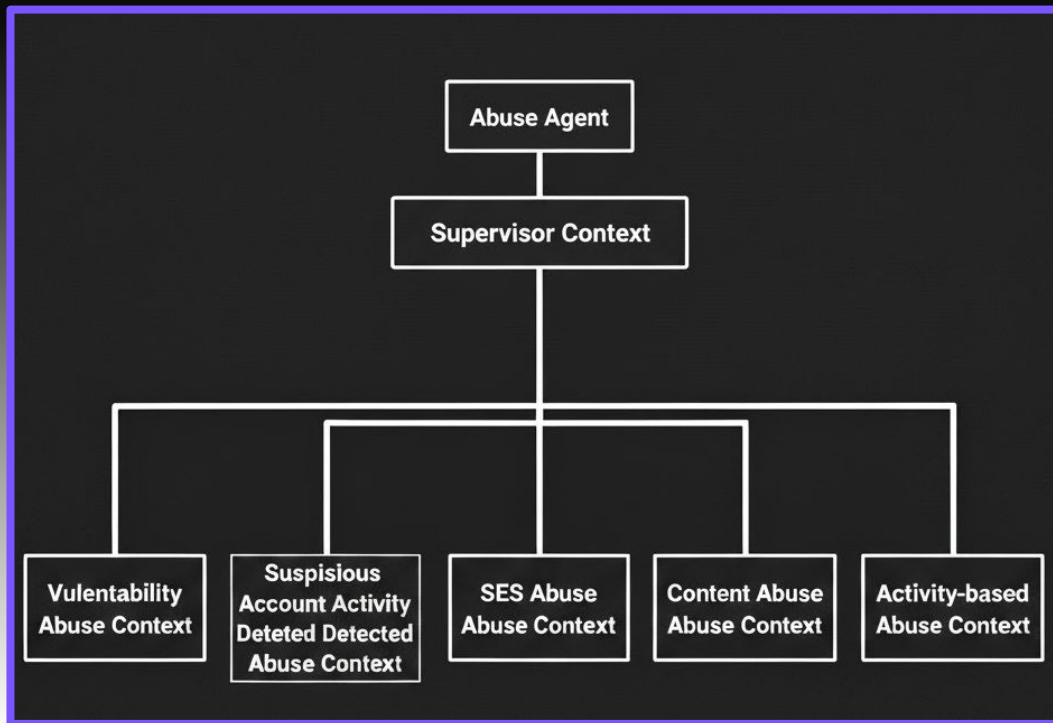
You can use `/editor` to edit your prompt with a vim-like experience

Model: auto (/model to change)

[abuse] 1% > \

Abuse 대응용 특화 Context를 가진 Kiro Cli-Agents

유형별 Context를 보유한 Abuse Cli-Agent Flows



Abuse 대응용 특화 Context를 가진 Kiro Cli-Agents

1) Supervisor Context

아래 정보를 입력받으면 슈퍼바이저 에이전트는 입력된 Event 유형을 확인하여 아래 분류에 따라 적절한 하위 에이전트를 실행시키고, 모든 입력 정보를 해당 에이전트의 분석 로드맵에 맞게 전달합니다.

Account ID(12자리 고객 계정 ID) : 필수 정보. 역할 전환 및 분석 대상 지정에 사용됩니다.

Event(발생한 어뷰즈 유형) : 필수 정보. 실행할 하위 에이전트 결정 기준으로 사용됩니다.

Detail(\$\text{Event}\$에 관련된 자세한 정보) : 선택 정보. 하위 에이전트의 분석 로드맵 및 초기 탐색 기준으로 활용됩니다.

Case ID(AWS 서포트 케이스 ID) : 선택 정보. 조치사항에 영문 회신 안내에 활용됩니다.

IAM User(s)(관련된 IAM 사용자 목록) : 선택 정보. CloudTrail 분석의 주체 지정에 활용됩니다.

Access Key(s)(침해된 것으로 의심되는 액세스 키 목록) : 선택 정보. CloudTrail 분석의 주체 지정 및 삭제 조치 권고에 활용됩니다.



Account ID(12자리 고객 계정 ID) : 필수 정보. 역할 전환 및 분석 대상 지정에 사용됩니다.

Event(발생한 어뷰즈 유형) : 필수 정보. 실행할 하위 에이전트 결정 기준으로 사용됩니다.

Detail(\$\text{Event}\$에 관련된 자세한 정보) : 선택 정보. 하위 에이전트의 분석 로드맵 및 초기 탐색 기준으로 활용됩니다.

Case ID(AWS 서포트 케이스 ID) : 선택 정보. 조치사항에 영문 회신 안내에 활용됩니다.

IAM User(s)(관련된 IAM 사용자 목록) : 선택 정보. CloudTrail 분석의 주체 지정에 활용됩니다.

Access Key(s)(침해된 것으로 의심되는 액세스 키 목록) : 선택 정보. CloudTrail 분석의 주체 지정 및 삭제 조치 권고에 활용됩니다.

Abuse 대응용 특화 Context를 가진 Kiro Cli-Agents

1) Supervisor Context

```
/help all commands * ctrl + j new lines * ctrl + s fuzzy search
```

```
■ You are chatting with claude-sonnet-4
```

```
[abuse] > [redacted] 계정에서 [redacted] 사이에 비인가 리소스 생성이 있는지 확인해줘
```

```
> 9967 [redacted]: 계정의 비인가 리소스 생성 여부를 확인하겠습니다. 먼저 역할 전환을 수행한 후 CloudTrail을 통해 해당 기간의 리소스 생성 활동을 분석하겠습니다.
```



특정 상황에 맞는 이벤트 유형이 아니더라도, 일반적인 자연어를 통한 질의도 가능함.

하지만 컨텍스트에는 다음과 같은 abuse 관련 파일들이 있습니다:

- /home/ec2-user/agentcontext/Content_Abuse.md
- /home/ec2-user/agentcontext/Suspicious_Account_Activity_Detected_Abuse.md
- /home/ec2-user/agentcontext/Activity_base_Abuse.md
- /home/ec2-user/agentcontext/SES_Abuse.md
- /home/ec2-user/agentcontext/Vulnerability.md
- /home/ec2-user/agentcontext/supervisor.md

현재 상황 (의심스러운 EC2 RunInstances 활동)은 Suspicious_Account_Activity_Detected_Abuse.md 파일의 가이드라인에 가장 적합할 것 같습니다. 이 파일은 유출된 Access Key나 계정 자격 증명 등의 비인가 사용 분석에 특화되어 있습니다.

특정 abuse context 파일을 활용한 정식 분석을 원하시나요?



자연어 질의한 내용을 적절한 Context 내용에 맞게 추천 요청도 가능하며, 실제로 유형이 분류되는 경우 Conext 파일을 명시적으로 지정하여 분석해달라고 하는 경우 더 좋은 결과가 나옴

Abuse 대응용 특화 Context를 가진 Kiro Cli-Agents

2) Suspicious Account Activity Detected Abuse Context 일부

```
[ec2-user@ip-172-31-36-84 agentcontext]$ cat Suspicious Account Activity Detected Abuse.md
# AWS Q CLI 에이전트 컨텍스트: Suspicious Account Activity Detected (GetCallerIdentity, API/Console Compromise, etc)

## I. 최상위 원칙 (Supervisor Context 기반)
1. **모드**: Read-Only 분석 모드 엄수.
2. **금지 사항**: 인프라 생성, 수정, 삭제 행위나 관련 코드는 절대 제안 금지.
3. **역할 전환**: `aws sts assume-role --role-arn "arn:aws:iam::[입력된 분석이 필요한 12자리 어카운트]:role/mz-support1" --role-session-name mzc_support1` 명령을 실행하여 어썬하고 mz-support 프로파일에 자격증명을 저장 후, mz-support 프로파일로 {입력된 분석이 필요한 12자리 어카운트}계정에 역할전환 후 분석을 수행.
4. (An error occurred (AccessDenied) when calling the..) 관련 에러가 생길 경우 mz-support 프로파일로 {입력된 분석이 필요한 12자리 어카운트}계정에 역할전환이 잘되어있는지 다시 확인.
5. CloudTrail 분석 시 무조건 awslabs.cloudtrail-mcp-server MCP 활용
```



입력한 어카운트에 자동으로 어썬하고, 실패할 경우 프로파일을 통하여 재시도하는 로직. **CloudTrail MCP Sever**를 최우선 활용

```
## II. 주요 분석 목표 및 대상
* **목표**: 유출된 Access Key 또는 계정 자격 증명의 비인가 사용 흔적 파악 및 초기 침해 지점 식별. **특히 Access Key가 온라인에 공개된 경우 (API/Console/etc Compromise) 해당 키를 사용한 모든 비정상 활동 및 침해 확산 여부 파악에 집중합니다.**
* **대상 리소스**: IAM 사용자 및 액세스 키, CloudTrail 이벤트
* **필수 정보**: Account ID, Event (Suspicious Account Activity Detected).
* **보조 정보**: IAM User(s), Access Key(s) (추가 분석에 활용).

## III. 세부 분석 절차
* **분석 로드맵 활용**: **Detail에 입력된 정보 (예: 공개된 Access Key URL, IP 주소, 타임스탬프 등)를 분석 로드맵의 초기 침해 지점 및 탐색 기준으로 활용**하여 CloudTrail 분석을 수행합니다.
```



명시된 IAM User, 액세스키, 타임스탬프 정보가 있다면 해당 리소스를 위주로 비인가 활동들을 검사하게 됨

Abuse 대응용 특화 Context를 가진 Kiro Cli-Agents

2) Suspicious Account Activity Detected Abuse Context 일부

```
### 1. CloudTrail 이벤트 분석 (CloudTrail MCP 활용)
* **분석 기준**: 어뷰즈 이벤트가 발생한 **엑세스 키, IAM 사용자**를 기준으로 가장 먼저 us-east-1 리전을 시작으로 의심스러운 API 호출 이력을 상세 분석.
* **집중 분석 API**:
  * **초기 정찰**: 비정상적인 IP 주소, 위치, 또는 시간대에서의 `sts:GetCallerIdentity` 및 기타 권한 확인 API 호출 이력 분석.
  * **비인가 리소스 생성/변경**: 자격 증명 탈취 후 자원을 생성(`RunInstances`, `CreateUser`, `CreateAccessKey`)하거나 변경(`PutUserPolicy`)하는 행위 분석.
  * **Console Compromise**: UserAgent가 Console인 이벤트 중 비정상적인 로그인 시도 또는 활동 분석.
  * **관련 리소스 이벤트**: Access Key 기준으로 관련 리소스에 대한 모든 이벤트 기록을 확인하여 어뷰즈 행위가 어떤 리소스에 영향을 미쳤는지 파악.
```



정보가 없는 경우 **GetCallerIdentity, RunInstances, CreateUser, CreateAccessKey, PutUserPolicy** 등의 필수 API 호출 분석

3) Activity base Abuse Context 일부

```
### 1. CloudTrail 이벤트 분석 (CloudTrail MCP 활용)
* **분석 기준**: 어뷰즈 이벤트가 발생한 **엑세스 키, IAM 사용자**를 기준으로 가장 먼저 us-east-1 리전을 시작으로 의심스러운 API 호출 이력을 상세 분석.
* **집중 분석 API**:
  * **보안 설정 변경**: `AuthorizeSecurityGroupIngress`, `ReplaceNetworkAclEntry` 등 비정상적인 보안 그룹/NACL 규칙 변경 시도.
  * **컴퓨팅 리소스 생성**: `RunInstances`, `CreateFunction` 등 비인가 리소스 생성 여부 확인.
  * **관련 리소스 이벤트**: **Detail에 명시된 리소스 ID**를 기준으로 해당 리소스의 생성, 변경, 수정 이력을 확인하여 어뷰즈 행위가 어떤 리소스에 영향을 미쳤는지 파악.
```



이 경우 **AuthorizeSecurityGroupIngress, ReplaceNetworkAclEntry, CreateFunction** 등의 필수 API 호출 분석
추가로 발급된 Ec2 Abuse Report에 명시된 리소스 ID가 있다면 해당 리소스를 추가적으로 분석

Abuse 대응용 특화 Context를 가진 Kiro Cli-Agents

4) SES Abuse Context 일부

```
# II. 주요 분석 목표 및 대상
* **목표** : 비정상적인 이메일 전송 활동의 원인 분석 및 자격 증명 탈취 여부 확인.
* **대상 리소스** : Amazon SES 통계 (Bounce/Complaint rate), CloudTrail 이벤트, CloudWatch Logs.
* **필수 정보** : Account ID, Event (SES Bounce rate / SES Credential Compromise / SES etc).

# III. 세부 분석 절차
* **분석 로드맵 활용** : **Detail에 입력된 정보 (예 : Bounce Rate 개선 요청 사항, 차단 이유, 중지된 리전 목록 등)를 분석 로드맵의 핵심 진단 기준으로 활용**하여 SES 통계 및 CloudTrail 분석을 수행합니다.

### 1. CloudTrail 이벤트 분석 (CloudTrail MCP 활용)
* **SES API 호출** : `SendEmail`, `SendRawEmail` 등 SES 관련 API 호출의 비정상적인 패턴 (빈도, 전송 소스 IP) 분석.
* **Credential Compromise 확인** : SES 전송에 사용된 IAM 사용자 또는 Access Key에 대한 의심스러운 활동 분석.

### 2. CloudWatch Logs 분석
* **로그 확인** : SES 관련 CloudWatch Logs를 확인하여 **Bounce 및 Complaint 알림**, 전송 오류 등의 상세 기록 분석.
```

➡ 높은 Bounce Rate가 예상되는 경우 SES 통계에서 최근 14일간의 Bounce Rate 계산 및 SES 인증 상태등을 조회 하는 Context

```
> ## 분석 완료

46C[REDACTED] 계정의 SES Bounce rate 이벤트에 대한 분석을 완료했습니다.

### 주요 발견사항 :

1. 높은 Bounce Rate 확인 : 약 14.36%로 AWS 권장 기준 5%를 크게 초과
2. SES 계정 상태 : us-west-2 리전에서 정상 운영 중이나 Bounce Rate 크게 증가
3. 최근 활동 : SES SMTP 사용자가 최근까지 활발히 사용함 (2023-10-16 04:32:00 UTC)
4. 인증 상태 : postmaster@[REDACTED] 정상 인증됨

### 즉시 조치 필요사항 :

1. Bounce Rate 개선 : 이메일 리스트 정리 및 유효하지 않은 주소 제거
2. Case 회신 : Case ID 1752[REDACTED]에 대한 영문 회신 필요
3. 발송 패턴 개선 : 점진적 발송량 조절을 통한 평판 회복

상세한 분석 결과와 개선 방안은 생성된 HTML 보고서 [REDACTED]_분석결과.html에서 확인하실 수 있습니다.
```

➡ 계산된 Bounce Rate 및 필요 조치사항에 대한 권고, 관련 html 보고서를 생성

Abuse 대응용 특화 Context를 가진 Kiro Cli-Agents

Supervisor Context



Suspicious Account Activity Detected Abuse Context

> 입력된 정보를 확인했습니다. **Suspicious Account Activity Detected - GetCallerIdentity** 이벤트에 대한 분석을 시작하겠습니다.
먼저 **mz-support** 프로파일로 계정 3[REDACTED] 역할 전환을 수행하겠습니다.

Abuse 대응용 특화 Context를 가진 Kiro Cli-Agents

Suspicious Account Activity Detected Abuse 관련 보고서 예시

🔍 분석 결과 요약

침해 확인: 불가리아 (BG) IP 주소 [redacted] 비정상적인 GetCallerIdentity API 호출이 2회 탐지되었습니다.

핵심 발견 사항:

1. **침해 시점:** 2025-09-30 04:32:51 UTC (Detail에 명시된 시간과 정확히 일치)
2. **침해 IP:** [redacted] (불가리아)
3. **침해된 자격증명:** Access Key AKIA[redacted] 360-access-key 사용자)
4. **활동 패턴:** 계정 정보 정찰 시도 (GetCallerIdentity, GetSendQuota, GetSMSAttributes)

긍정적 요소:

- 최소 권한 원칙이 적용되어 SES/SNS 접근이 차단됨
- 비인가 리소스 생성은 없었음 (정찰 활동에 그침)

즉시 조치

1. Access Key [redacted] IFG 즉시 비활성화 및 삭제
2. MFA 활성화 및 보안 강화
3. Case ID [redacted]로 회신

상세한 분석 결과는 20251016_327777718870_분석결과.html 파일에 저장되었습니다.

📁 분석 근거

CloudTrail 이벤트 증거

GetCallerIdentity 이벤트 (Event ID: a8d0e638-[redacted] cec105f4da1) - 시간: [redacted] 1:34:34Z - 소스 IP: [redacted]
195.[redacted] (불가리아) - User Agent: aws-cli/2.31.3 - Access Key: AKI[redacted] - 사용자: [redacted]-access-key
GetSMSAttributes 시도 (Event ID: 75284ffe-f9[redacted] f59b911809) - 시간: [redacted] 1:34:36Z - 동일 IP에서 권한 탐
색 시도 - AccessDenied로 차단됨

- 동일한 불가리아 IP에서 SNS 권한 탐색 시도
- AccessDenied 오류로 차단됨
- 이벤트 ID: 75284ffe-[redacted]-1df59b911809

2. IAM 사용자 보안 상태 분석

항목	상태	위험도
사용자 생성일	[redacted]	정상
Access Key 생성일	[redacted]	정상
MFA 활성화	❌ 비활성화	높음
마지막 사용	[redacted]	정상

Abuse 대응용 특화 Context를 가진 Kiro Cli-Agents

랜섬웨어 관련 타임 라인 보고서 작성 예시

⚠ 긴급 - 랜섬웨어 공격

AWS 클라우드 랜섬웨어 공격 통합 사고 분석 보고서

계정 ***** | CloudTrail 원본 데이터 기반 재검증 완료

계정 ID

공격 기간
6일 (Day 1 ~ Day 6)

공격자 IP
..***.***

침해 계정
[IAM_USER_A] (IAM User)

외부 계정

1 사고 개요 (Executive Summary)

****년 **월 **일 **:*:* KST부터 **월 **일 **:*:* KST까지 6일간 고도로 조직화된 클라우드 랜섬웨어 공격이 발생했습니다.

항목	내용
사고 유형	클라우드 랜섬웨어 (리소스 파괴 + KMS 키 하이재킹 + 데이터 탈취)
공격 기간	6일 (****-**-** **:*:* ~ ****-**-** **:*:* KST)
공격 벡터	[IAM_USER_A] IAM 자격증명 탈취 → GetFederationToken → aws_console 페더레이션
공격 도구	AWS Console, Python Boto3, .NET SDK, Go SDK, S3 Browser
랜섬 메시지	"Your data has been secured. All recovery paths have been eliminated. Contact for restoration."

3 상세 공격 타임라인 (CloudTrail 원본 검증 완료)

📅 타임라인 참고 사항:

Day 1 05:03:55 us-east-1 GetFederationToken이 최초 활동 / 공격 기간 6일

[IAM_USER_A]은 Day 1에 us-west-2 직접 활동 없음 (Events: []), 모든 us-west-2 활동은 aws_console 경유

📅 Day 1 (****-**-**) 초기 침투 및 정찰

- 14:03:55 us-east-1 **최초 활동**
[IAM_USER_A]: GetFederationToken → aws_console 세션 생성
IP: ***.***.***.*** | User-Agent: aws-sdk-dotnet-45 (Windows .NET 4.8) | 만료: 02:03:55
- 17:03:55 us-east-1
[IAM_USER_A]: GetFederationToken (2차 세션)
IP: ***.***.***.*** | 만료: 05:03:55
- 19:30:30 us-east-1
[IAM_USER_A]: GetFederationToken (3차 세션)
IP: ***.***.***.*** | 만료: 07:30:30

Abuse 대응용 특화 Context를 가진 Kiro Cli-Agents

랜섬웨어 관련 타임 라인 보고서 작성 예시

17 Day 2 (****-**-**): 환경 매핑

02:29~06:46 us-east-1

[IAM_USER_A]: S3/CloudFront 전체 열거 (ListBuckets x**, GetBucketLocation x**, ListDistributions x**)

다수 IP: *.***.***.*** | User-Agent: S3 Browser/13.1.1

종일 us-west-2

i-*****: SSM 에이전트 활동 (UpdateInstanceInformation x**)

17 Day 3 (****-**-**): 랜섬웨어 배포 (S3 암호화 + 대규모 스냅샷 삭제)

19:53:23~ us-east-1

[IAM_USER_A]: S3 버킷 위치 확인

IP: *.***.***.*** | User-Agent: aws-sdk-go-v2/1.30.1 (Linux, Go 1.26.0)

GetBucketLocation x**, ListBuckets x*, DescribeRegions x*, DescribeVolumes x*

시간 미상 us-west-2 대규모 삭제

aws_console: EBS 스냅샷 **개 삭제

DeleteSnapshot x** | DescribeSnapshots x**

snap-***** (총 **개, 상세 ID 마스킹)

08:20:35-36 us-west-2 ★ 랜섬웨어

[IAM_USER_A]: S3 객체 ***개 외부 KMS 키로 암호화

KMS GenerateDataKey x*** (1-2초 내 버스트)

KMS 키: arn:aws:kms:us-west-2:*****:key/*****_****_****_*****

외부 계정(*****)의 키로 암호화 → 공격자 키 없이 데이터 접근 불가

4 피해 상세 (전체 리소스 목록)

EC2 인스턴스 종료 (**개)

종료: Day 6 06:01-06:04 KST | 실행자: [EC2_ROLE_A] (i-*****)

i-***** i-***** i-***** i-*****
i-***** i-***** i-***** i-*****
... (총 **개 인스턴스 ID 마스킹)

Abuse 대응용 특화 Context를 가진 Kiro Cli-Agents

랜섬웨어 관련 타임 라인 보고서 작성 예시

7 즉시 대응 조치 (24시간 이내)

● 최우선 조치 - 즉시 실행 필요

1. 자격증명 무효화

```
# [IAM_USER_A] 액세스 키 비활성화 + 임시 차단
aws iam update-access-key --user-name [IAM_USER_A] --access-key-status Deactivated
aws iam put-user-policy --user-name [IAM_USER_A] --policy-name DenyAll --policy-document '{"Effect":"Deny","Action":["*"],"Resource":["*"]}'
```

8 복구 조치

조치	상세
스냅샷 복구	AWS Backup 볼트 확인, 다른 리전 복제본 확인, AWS Support 케이스 생성
EC2 복구	최근 AMI에서 인스턴스 재생성, 오프사이트 백업 복원
포렌식	i-***** EBS 볼륨 스냅샷 (증거 보존), /var/log/auth.log, ~/.bash_history 분석
계정 정리	[IAM_USER_A]: 키 삭제→새 키(90일 로테이션)→MFA [IAM_USER_B]: 사용 여부 확인

Abuse 대응용 특화 Context를 가진 Kiro Cli-Agents

비인가 생성 리소스 관련 리전 조회 필요시 'Resource Explorer' 사용

재:발명하다 | AWS 알아보기 | 제품 | 솔루션 | 가격 | 자원

Q | 콘솔에 로그인하세요 | 계정 생성

AWS는 이제 지역 내에서 즉각적인 리소스 검색을 지원합니다.

게시일: 2025년 10월 13일

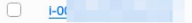
AWS는 이제 AWS Resource Explorer를 통해 모든 계정에서 리소스 검색 기능에 즉시 액세스할 수 있도록 합니다.이 출시로 더 이상 Resource Explorer를 활성화하여 리전에서 리소스를 검색할 필요가 없습니다.

 [AWS Resource Explorer](#) > 리소스**AWS 리소스 탐색기** <**리소스 살펴보기**[리소스](#)

보기

설정

지원되는 리소스 유형 **리소스 구성**리소스 그룹 태그 정책 **리소스 공유****리소스 (21) 정보** 보기  all-resources  선택 사항  Q. 쿼리 키워드, 필터 및 연산자 리소스 유형 = ec2:instance   쿼리 복사  필터 지우기

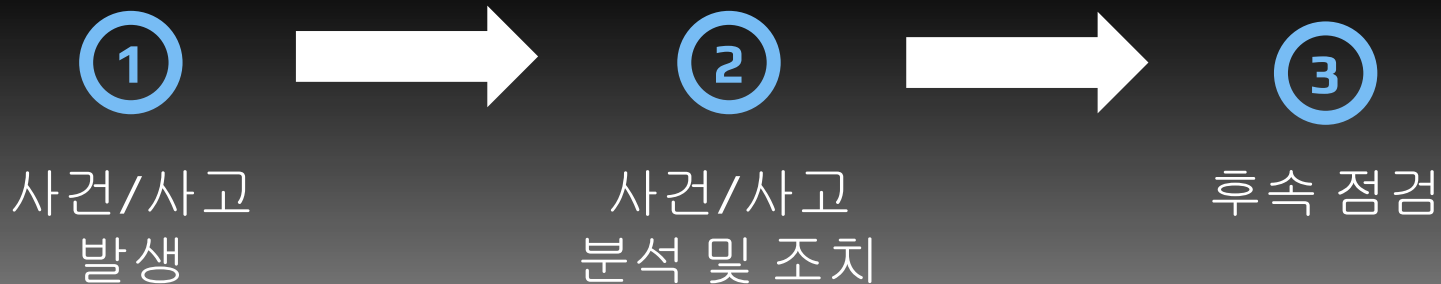
☐	식별자 	서비스	리소스 유형	리전
☐		ec2	ec2:instance	아시아 태평양 (도쿄) ap-northeast-1
☐		ec2	ec2:instance	아시아 태평양 (서울) ap-northeast-2
☐		ec2	ec2:instance	아시아 태평양 (서울) ap-northeast-2
☐		ec2	ec2:instance	아시아 태평양 (서울) ap-northeast-2
☐		ec2	ec2:instance	아시아 태평양 (서울) ap-northeast-2
☐		ec2	ec2:instance	아시아 태평양 (오사카) ap-northeast-3

TIP



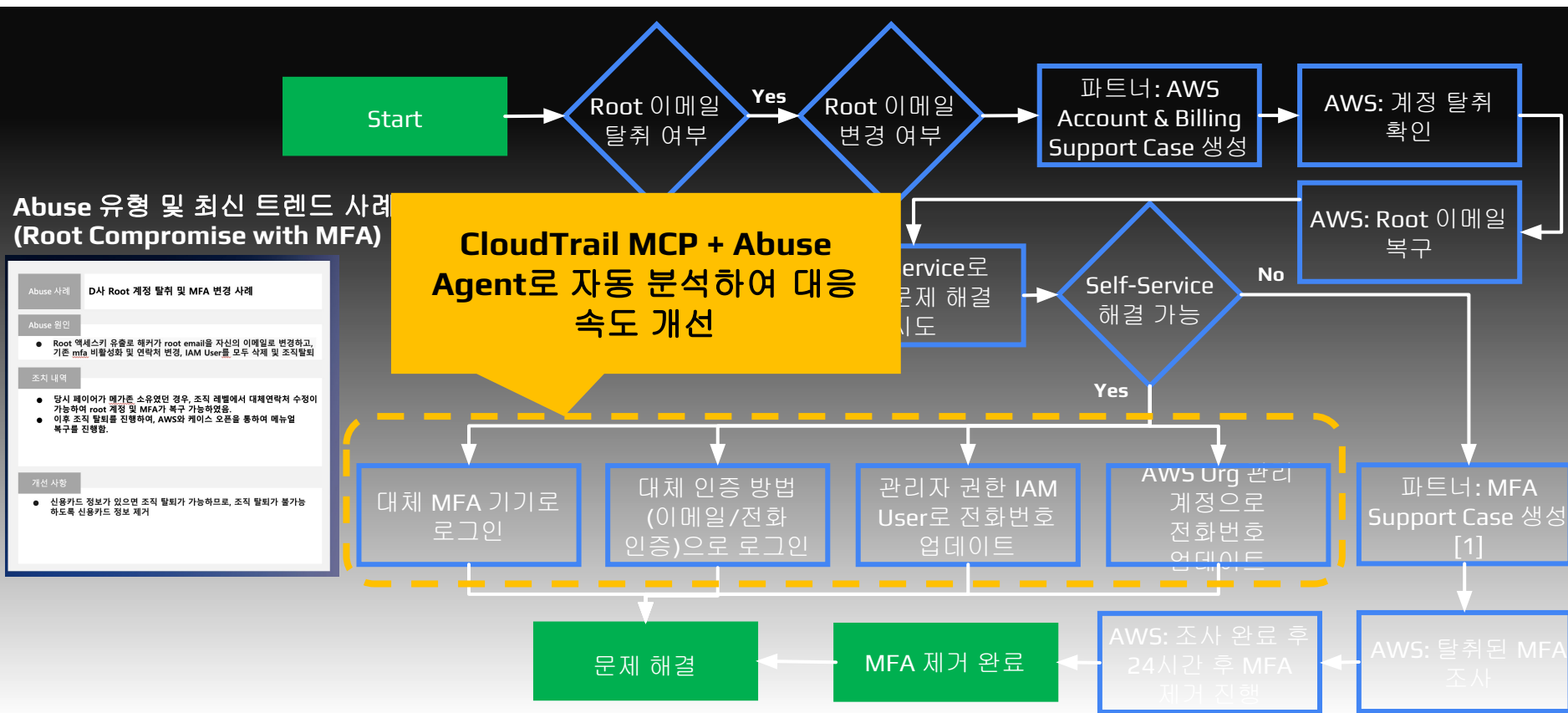
모든 리전에서 조회를 하는 경우 할루시네이션(hallucination)이 발생할 수 있으므로, 특정 리전을 먼저 인지 후 조회하는 것을 추천

Lessons Learned



↑
Kiro CLI with CloudTrail MCP를
활용한 분석 속도 개선(+다만,
대량 호출의 경우 TPS에
제한되므로 임계치에 따라 코드
병행 사용)

Lessons Learned



<https://support.aws.amazon.com/#/contacts/one-support?formId=mfa>



Thank You!

감사합니다.

허준, June Her

Commercial Managed > Tech Support
Service > Tech Support 1 / Unit Leader
메가존클라우드(MegazoneCloud)

 [linkedin.com/in/june-her-50888112a](https://www.linkedin.com/in/june-her-50888112a)